

Lecture 04: Reversing Tools

August 26, 2024

Overview

- ▶ Reversing Approaches
- ▶ Disassemblers
- ▶ Debuggers
- ▶ Virtual Machines
- ▶ Decompilers
- ▶ System-Monitoring Tools
- ▶ Patching Tools
- ▶ Miscellaneous

There are a variety of tools: some free, some commercial.

There is no all-in-one, though IDA is closest.

Reversing Approaches

There are many approaches, but they fall generally into two methodologies. Which is appropriate depends on the circumstances and the information desired.

Offline, Static, Dead Listing

- ▶ Analysis *without* executing the code
- ▶ Usually disassemblers and decompilers
- + Safer for malware
- + Provides a good outline of the program
- Requires a better understanding of code
- Usually a more advanced approach
- Sometimes not possible, e.g., packed programs

Reversing Approaches

Online, Dynamic, Live Code

- ▶ Analysis *with* code execution
- ▶ Usually debuggers (often including a disassembler, and maybe a decompiler)
- ⊕ Can observe the program's behavior
- ⊕ Can see actual data and how it affects program flow
- ⊕ Easy for beginners to start
- ⊖ Requires precautions for malware
- ⊖ Can get tunnel vision, i.e., miss some code paths

Disassemblers

- ▶ Decodes binary machine code into readable assembly
- ▶ Inherently platform-dependent (may support many)
- ▶ Each instruction translated into textual opcode and optional parameters

Telling code from data

- ▶ usually `.text` contains code and `.data` contains data
- ▶ sometimes small portions of data in `.text` section, e.g., jump tables
- ▶ might just pass linearly (very problematic)
- ▶ might disassemble at entry point and follow possible paths (might miss some, e.g., dynamic jumps)

Disassemblers

IDA Pro

- ▶ Interactive Disassembler by Hex-Rays¹
- ▶ Supports many OSes, processors, and file formats
- ▶ \$589 for Starter, \$1,129 for Professional (required for x64)
- ▶ Demos and v5.0 available for free (current is ≥ 6.6)
- ▶ Includes a decompiler
- ▶ Many, many features, and a fairly robust plugin ecosystem
- ▶ Annotated disassembly view
- ▶ Intra-function (flow chart) and inter-function (call graph) views

¹www.hex-rays.com

Disassemblers

ILDasm

- ▶ Tool provided by Microsoft (part of VS Developer Console) to disassemble MSIL .NET programs
- ▶ May be thwarted with, e.g., Dotfuscator

Debuggers

- ▶ Usually for developers to locate and correct errors
- ▶ Can step through assembly (or source if available)
- ▶ Shows registers, memory (stack) between each step
- ▶ Desired Features:
 - ▶ Powerful disassembler - need to see the code as it executes
 - ▶ It's nice if it also displays branch targets
 - ▶ Should be able to control code vs. data
 - ▶ Software and Hardware Breakpoints

software special int 3 instruction overwrite breaks to debugger

hardware CPU breaks to debugger when certain address accessed a certain way

Debuggers

Breakpoints

Software

Hardware

Debuggers

Breakpoints

Software

- ➕ Practically unlimited in number
- ➖ Execution breakpoints only
- ➖ Can be detected by debuggee

Hardware

- ➕ Can also do read and write breakpoints
- ➖ Only 4 ranges (on x86) with sizes of 1, 2, 4, or 8 bytes

Debuggers

- ▶ Desired Features:
 - ▶ View of Registers and Memory
 - ▶ should provide important registers and memory, esp., stack
 - ▶ should try to interpret stack/memory contents, but still display raw
 - ▶ Process Information
 - ▶ e.g., currently loaded modules
 - ▶ currently running threads
 - ▶ stack/register dump for each thread

User-Mode Debuggers

- ▶ the more conventional debugger
- ▶ runs as a normal application attached to the debuggee
- ⊕ easy to set up and use
- ⊖ can only view a single process
- ⊖ can only debug the user-mode code accessed by the process
- ⊖ some cannot debug before `WinMain`

User-Mode Debuggers

OllyDbg

- ▶ one of the best debuggers built for reversing
- ⊕ has a very nice disassembler with some control structure detection
- ⊕ has built-in references for well-known APIs
- ⊕ supports searching for cross references
- ⊕ lists imports and exports of modules
- ⊕ lists windows, objects owned by debuggee
- ⊕ built-in assembly / patching
 - ▶ shareware
- ⊕ can load symbols
- ⊕ plug-in system (see OpenRCE)
- ⊖ 64-bit support is still alpha

User-Mode Debuggers

WinDbg

- ▶ Free from Microsoft (part of Windows SDK)
- + very powerful command line and scripting
- + well-integrated with Windows (reads its objects and structures)
- + plug-in system, integrates with IDA
- + can break before WinMain
- + 32- and 64-bit
- lacks some code-analysis features
- GUI is not particularly friendly

User-Mode Debuggers

IDA Pro

- ▶ has a built-in user-mode debugger
- ▶ integrated reversing and debugging interface
- ▶ can also interface with WinDBG
- ⊕ 32- and 64-bit
- ⊖ not available in free version

User-Mode Debuggers

PEBrowse Professional Interactive

- ▶ a PE dumper that includes a decent debugger
- ▶ view allocated heaps and allocated blocks within them
- ⊕ also supports .NET programs
- ⊕ free
- ⊕ 32- and 64-bit
- ⊕ can break before `WinMain`
- ⊖ UI is a little clunky

There are many more debuggers online.

Kernel-Mode Debuggers

- ▶ when you need to control the whole system
- ▶ usually for developing device drivers
- ▶ some reversers prefer them exclusively
- ⊕ some still support debugging a user-mode process
- ⊕ can set low-level breakpoints, no worries about particular API
- ⊖ must side “beside” the kernel
- ⊖ difficult to get set up (a little easier with VMs, though)

Kernel-Mode Debuggers

WinDbg

- ▶ debuggee (Windows OS) must be booted with debug enabled
- ▶ connected via null modem, FireWire, named pipes, or network
- ▶ can also use command-line interface, KD
- ⊕ primarily a kernel-mode debugger
- ⊕ 32- and 64-bit
- ⊖ must be remote from the debuggee

Kernel-Mode Debuggers

Numega SoftICE

- ▶ device driver development
- ▶ implemented as a device driver
- ▶ a hotkey pauses the entire system and breaks to softICE
- + can debug on same computer as debuggee
- + reads MS symbol files
- + can understand and dump many system structures
- DISCONTINUED 2006
- + fast (no connection bottleneck)
- + can load WinDbg plugins
- tends to destabilize the system
- cannot step through, e.g., window drawing code
- limited x64 support

Kernel-Mode Debuggers

Alternatives to SoftICE

▶ Syser

⊕ Claims to work with Windows 8

⊖ Site tends to be down

▶ Rasta Ring 0 Debugger

⊕ Claims to work with many OSes

⊖ Last updated 2008

▶ HyperDBG

▶ Relies on hardware-assisted virtualization

⊕ can step through kernel-mode exception handlers

⊖ Last updated 2010

Virtual Machines

- ▶ You should never kernel debug your primary work machine
- ▶ You should avoid debugging suspicious programs on bare metal
- ▶ hardware is virtual, e.g., screen $\implies$ window, disk $\implies$ file
- + can quickly instantiate and destroy experimental systems
- + can snapshot and revert machines and/or networks
- + can run multiple instances
- + some can emulate other CPUs
- requires a rather powerful host
- some malware may detect the VM

Virtual Machines

VMware Workstation

- ▶ First to virtualize x86
- ▶ Integrates well with other VMware solutions

VirtualBox

- ▶ Open source (started by Sun, now Oracle)

Microsoft Virtual PC

- ▶ Windows host

Xen

- ▶ Requires Linux “dom0”
- ▶ Open source (bought by Citrix)
- ▶ More for cloud infrastructure

KVM/kqemu

- ▶ Linux host
- ▶ Open source
- ▶ More for cloud infrastructure

Decompilers

- ⊕ “Dream tool” to convert binary to source code
- ⊖ compilation causes unrecoverable loss
 - ▶ e.g., variable names
 - ▶ e.g., file organization

Platform	Decompiler
C	\$ Hex Rays, ↓ Boomerang, C4Decompiler
Java	JAD, JD, Mocha
.NET	DotPeek, \$ Salamander

System-Monitoring Tools

- ▶ Observe I/O or other OS channels
- ▶ Hooks low-level OS functions

Sysinternals

- ▶ developed by Mark Russinovich, now employed by Microsoft
- ▶ authority on Windows internals
- ▶ latest tools available on Microsoft TechNet

System-Monitoring Tools

Sysinternals

TCPView view active and listening IP connections

LiveKd kernel debug the local system

WinObj view named objects

Process Explorer task manager++

Process Monitor view file and registry accesses

System-Monitoring Tools

Wireshark

- ▶ Full network packet capture
- ▶ Built-in and pluggable parsers
- ▶ Consider `tcpdump` for large captures

Patching Tools

- ▶ Modify code to alter its behavior
- ▶ Usually after some RE, esp., by crackers

Hex Workshop

- ⊕ can edit files or entire disks
- ⊖ no disassembler
- ⊕ can interpret data as structures

Executable-Dumping Tools

DUMPBIN Comes with MSVC - displays sections, imports, exports, etc.

objdump GNU binutils - similar, integrated disassembler

PEView similar, includes GUI and raw section data view

PEBrowse Professional companion to Interactive

Forensic Tools

- ▶ usually for malware analysis

Volatility memory analysis framework

- ▶ analyze memory snapshots, e.g., from a VM
- ▶ understands OS data structures

Cuckoo sandbox

- ▶ automatically execute binaries and scripts in controlled environment
- ▶ performs system monitoring and API call traces

Conclusion

- ▶ Disassemblers
- ▶ Debuggers
- ▶ Virtual Machines
- ▶ Monitoring Tools
- ▶ Miscellaneous Tools